

Target
lab.example

Active Directory · tier 0 · 2026-10-07 18:46 UTC · snapshot d03c5d0b...

212

checked

188

passed

12

with findings

21

findings

12

skipped

QUICK WINS — UNDER 10 MINUTES EACH

- 1

Set the machine-account quota to 0.

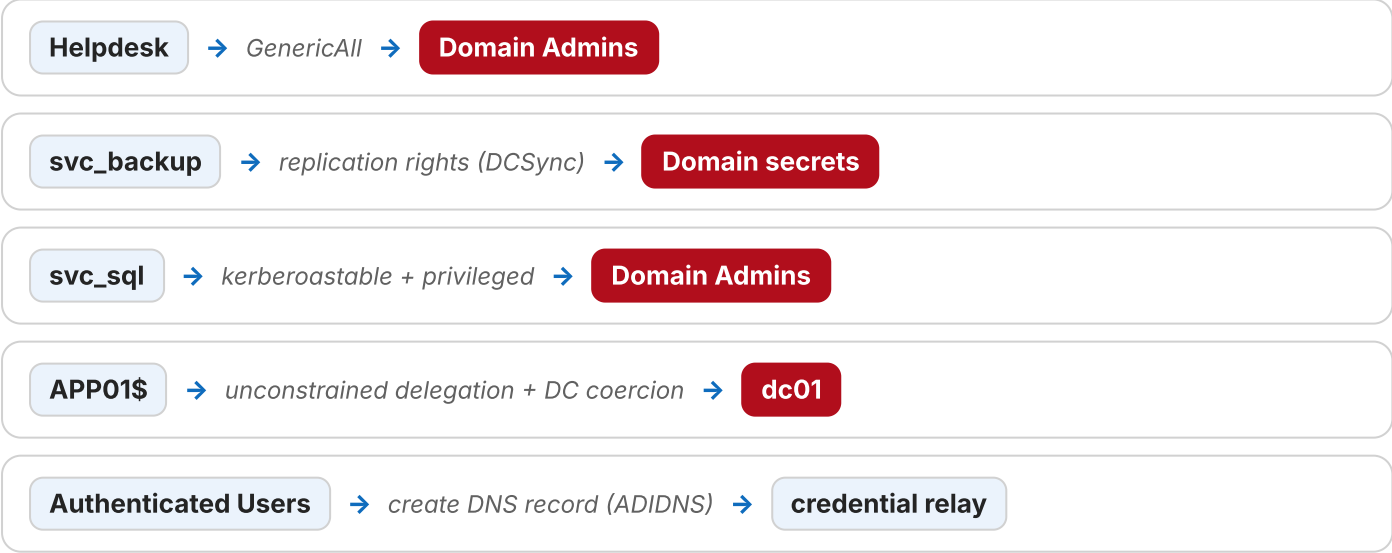
Set-ADDomain -Identity lab.example -Replace @{"ms-DS-MachineAccountQuota"="0"}
- 2

Remove GenericAll for "Helpdesk" on the Domain Admins group.

One ACE removal closes a direct path to Tier 0.
- 3

Clear the reversible-encryption flag on svc_legacy and reset its password.

TOP 5 PATHS TO TIER 0



FINDINGS

CRITICAL

DSA-0015

Shadow admin — dangerous rights on a privileged object

1 object(s) · Directory core

AFFECTED

Group "Helpdesk" → CN=Domain Admins,CN=Users,DC=lab,DC=example

GenericAll

WHY IT MATTERS

An account outside the admin groups holds an ACL permission (GenericAll) over the Domain Admins group. Such accounts are easy to miss because they are not group members, yet they can grant themselves full control.

REMEDIATION

Remove the GenericAll ACE unless it is a documented delegation; audit who may change ACLs on Tier-0 objects; place Tier-0 objects under a monitored, least-privilege delegation model.

MITRE ATT&CK

T1098 · Account Manipulation

T1222.001 · File/Directory Permissions Modification: Windows

REFERENCES

- [CyberArk — Shadow Admins](#)
- [SpecterOps — An ACE Up the Sleeve](#)

CRITICAL

DSA-0014

Replication (DCSync) rights held by a non-Tier-0 account

1 object(s) · Directory core

AFFECTED

CN=svc_backup,CN=Users,DC=lab,DC=example

DS-Replication-Get-Changes-All on domain head

WHY IT MATTERS

The account has the directory-replication extended rights on the domain, which allow pulling password material for every account over the network — equivalent to Domain Admin for credential theft.

REMEDIATION

Remove the replication ACEs from any principal that is not a domain controller or a documented Tier-0 service; review the domain-head DACL; alert on new grants.

MITRE ATT&CK

T1003.006 · OS Credential Dumping: DCSync

REFERENCES

- [ADSecurity — Mimikatz DCSync](#)
- [MS-ADTS](#)

CRITICAL

DSA-0002

Privileged account exposed to Kerberoasting (has an SPN)

1 object(s) · Directory core

AFFECTED

CN=svc_sql,CN=Users,DC=lab,DC=example

member of Domain Admins · SPN MSSQLSvc/db01

WHY IT MATTERS

A member of a Tier-0 group has a service principal name, so any domain user can request a service ticket encrypted with this account's key and attack it offline. For a privileged account that key is a domain-takeover secret.

REMEDIATION

Remove the SPN from the privileged account; run the service under a group-managed service account; enforce AES-only keys and a 25+ character random password where an SPN must remain.

MITRE ATT&CK[T1558.003 · Steal or Forge Kerberos Tickets: Kerberoasting](#)**REFERENCES**

- [ADSecurity — Kerberoast](#)
- [ATT&CK T1558.003](#)

CRITICAL

DSA-0060

Group Policy Preferences password (cpassword) in SYSVOL

1 object(s) · Group Policy

AFFECTED

\\lab.example\SYSVOL\...\Groups.xml

cpassword attribute present

WHY IT MATTERS

A Group Policy Preferences item stores a password encrypted with a key Microsoft published in MS-GPPREF, so anyone who can read SYSVOL (every domain user) can decrypt it. Microsoft removed the feature in MS14-025.

REMEDIATION

Remove the cpassword from the GPP XML in SYSVOL; change the exposed account's password; apply MS14-025; prefer LAPS for local admin passwords.

MITRE ATT&CK[T1552.006 · Unsecured Credentials: Group Policy Preferences](#)**REFERENCES**

- [MS14-025](#)
- [MS-GPPREF 2.2.1.1.4](#)

HIGH

DSA-0004

Unconstrained Kerberos delegation on a non-DC host

1 object(s) · Directory core

AFFECTED

CN=APP01, OU=Servers, DC=lab, DC=example

TRUSTED_FOR_DELEGATION (0x80000)

WHY IT MATTERS

A host with unconstrained delegation caches the Kerberos TGT of every user that authenticates to it, including privileged ones. Control of that host can lead to reuse of those tickets.

REMEDIATION

Replace with resource-based or classic constrained delegation; mark Tier-0 accounts 'sensitive, cannot be delegated' and add them to Protected Users.

MITRE ATT&CK[T1550.003 · Use Alternate Authentication Material: Pass the Ticket](#)[T1187 · Forced Authentication](#)**REFERENCES**

- [Microsoft — Kerberos constrained delegation](#)
- [Microsoft — UserAccountControl flags](#)

HIGH

DSA-0001

Accounts that do not require Kerberos pre-authentication (AS-REP roastable)

2 object(s) · Directory core

AFFECTED

CN=j.legacy, CN=Users, DC=lab, DC=example

DONT_REQ_PREAUTH

CN=kiosk, CN=Users, DC=lab, DC=example

DONT_REQ_PREAUTH

WHY IT MATTERS

With pre-authentication disabled the KDC returns, to anyone who asks, a response whose encrypted part is derived from the account's password — allowing an offline password attack.

REMEDIATION

Clear the 'do not require Kerberos pre-authentication' flag unless a documented legacy client needs it; set a long random password meanwhile.

MITRE ATT&CK[T1558.004 · Steal or Forge Kerberos Tickets: AS-REP Roasting](#)**REFERENCES**

- [Microsoft — UserAccountControl flags](#)
- [ATT&CK T1558.004](#)

HIGH

DSA-0011

Password stored with reversible encryption

1 object(s) · Credentials

AFFECTED

CN=svc_legacy,CN=Users,DC=lab,DC=example

ENCRYPTED_TEXT_PWD_ALLOWED

WHY IT MATTERS

Reversible encryption is cleartext storage with an extra step: anyone who can read the directory database recovers the actual password.

REMEDIATION

Disable 'store password using reversible encryption' at the account and domain level; force a password change for affected accounts.

MITRE ATT&CK

T1003.006 · OS Credential Dumping: DCSync

REFERENCES

- [Microsoft — Store passwords using reversible encryption](#)

HIGH

DSA-0041

Authenticated Users can create records in an AD-integrated DNS zone

1 object(s) · DNS

AFFECTED

DC=lab.example,CN=MicrosoftDNS,DC=DomainDnsZones,DC=lab,DC=example

Create-Child for Authenticated Users

WHY IT MATTERS

The default ADIDNS zone ACL lets any authenticated user add DNS records. Combined with name-resolution behaviour this enables credential-relay positioning without any elevated right.

REMEDIATION

Tighten the zone DACL so only authorised principals create records; add WPAD/ISATAP to the DNS global query block list; monitor for new records.

MITRE ATT&CK

T1557 · Adversary-in-the-Middle

REFERENCES

- [Kevin Robertson — Exploiting ADIDNS](#)
- [MS-DNSP](#)

HIGH

DSA-0040

DNS zone allows insecure dynamic updates

1 object(s) · DNS

AFFECTED

zone lab.example

fAllowUpdate = ZONE_UPDATE_UNSECURE (1)

WHY IT MATTERS

The zone accepts updates without authentication (MS-DNSP DNS_ZONE_UPDATE value 1), so any host on the network can create or overwrite records, including those used for name resolution of critical services.

REMEDIATION

Set the zone to secure dynamic updates only (ZONE_UPDATE_SECURE); for AD-integrated zones this is the default and recommended setting.

MITRE ATT&CK

T1557 · Adversary-in-the-Middle

REFERENCES

- [MS-DNSP 2.2.6.1.1 DNS_ZONE_UPDATE](#)
- [Microsoft — Securing DNS zones](#)

HIGH

DSA-0065

GPO grants a sensitive user right to a broad group

1 object(s) · Group Policy

AFFECTED

GPO "Workstation Baseline" → GptTmpl.inf

SeDebugPrivilege = Authenticated Users

WHY IT MATTERS

A policy assigns a powerful privilege (here, Debug programs) to a broad group. On every machine the GPO applies to, members of that group gain an ability normally reserved for administrators.

REMEDIATION

Remove the privilege assignment from broad groups; grant sensitive user rights only to the minimum required principals; review the GPO's link scope.

MITRE ATT&CK

T1484.001 · Domain Policy Modification: Group Policy Modification

REFERENCES

- [MS-GPSB — Security Protocol Extension](#)
- [ATT&CK T1484.001](#)

MEDIUM

DSA-0008

krbtgt password has not been rotated

1 object(s) · Kerberos

AFFECTED

CN=krbtgt,CN=Users,DC=lab,DC=example

pwdLastSet = 712 days ago

WHY IT MATTERS

The krbtgt key signs every Kerberos ticket-granting ticket. If it was ever exposed, forged tickets stay valid until the key is changed twice. Microsoft's recovery guidance resets it twice, 10 hours apart.

REMEDIATION

Reset the krbtgt password twice with at least 10 hours (the maximum ticket lifetime) between resets, and schedule the rotation periodically.

MITRE ATT&CK[T1558.001 · Steal or Forge Kerberos Tickets: Golden Ticket](#)**REFERENCES**

- [Microsoft — Reset the krbtgt password](#)
- [ATT&CK T1558.001](#)

MEDIUM

DSA-0013

**Any user may add computers to the domain
(machine-account quota)**

1 object(s) · Directory core

AFFECTED

DC=lab,DC=example

ms-DS-MachineAccountQuota = 10

WHY IT MATTERS

Every authenticated user can create up to ten computer accounts and control their attributes. This is the starting point for several delegation- and relay-based privilege escalations.

REMEDIATION

Set ms-DS-MachineAccountQuota to 0 and delegate computer joining to a dedicated group or an OU-scoped permission.

MITRE ATT&CK[T1136.002 · Create Account: Domain Account](#)**REFERENCES**

- [Microsoft — ms-DS-MachineAccountQuota](#)
- [Microsoft — default workstation join limit](#)

SKIPPED — AND WHY

12 checks not run because they need Tier 2 (an admin account): NTLM level, SMBv1, Print Spooler on DCs, applied audit policy, local administrators on DCs, LAPS state...

Generated read-only; nothing left this machine. 212 checks run as audit@lab.example over Kerberos. Report hash e7b0c2...